Focused acceptance criteria and approval gates

Use these criteria to decide whether the lab meets the assignment. The analyst must be able to read reports, the engineer must be able to read maintenance instructions, and the unassigned user must be denied. The lab must also demonstrate isolation, restricted administration, remote access and application recovery. Assignment · Glossary

Obtain explicit owner approval before each implementation stage A-L. Record the stage, scope, assets, permitted changes, validation and rollback. Service migration, shutdown and destructive recovery need approval for the exact assets and recovery procedure. Destructive disk work also needs the exact disk identity and a recoverable backup plan. Verify lawful software and provider terms. Keep service-dependent checks NOT TESTED until the approved service and evidence are available. Approval rules · Lab Implementation Guide

1. Measurable completion criteria

All ten criteria are mandatory for engineering completion. Each row maps to an assignment requirement (FWR), security control (FSC) and formal test (FWT). Use the Test Plan for exact scopes, expected outcomes and second observations. Requirements · Security controls · Coverage index

Table 1. Measurable completion criteria

ID	Required evidence	Mapping
FAC-01	**Prepared environment and isolation.** Verify equipment identity and ownership, compatible, supported versions, existing data and services, original disk protection, approved backups and Dell/HP console recovery. Trace cables, the TP-Link TL-SG108E, Dell bridges and workload network interfaces (NICs) to physical HP OPNsense. Check IPv4 and IPv6 routes and forwarding, extra adapters, Wi-Fi, virtual private networks (VPNs) and automatic routes. Verify separation from home and production networks, trust, data and credentials. Keep the GL.iNet Beryl AX uplink disconnected until independent isolation, scoped egress and rollback are approved. Under stage A and applicable network approvals, pair inspection with a working allowed control and denial at a known-listening lab-owned mock. Match that denial to HP's effective rule and log or counter. Observe real protected boundaries passively.	FWR-01, FSC-01, FWT-01
FAC-02	**Segmentation and capacity.** One Dell Precision 5820 Proxmox VE host runs exactly three workload virtual machines (VMs). DC1 (Windows Server) and WIN1 (Windows domain client) share Corporate. APP1 (Linux and Apache HTTPS) uses Restricted. Management is reserved for the dedicated administrator and named interfaces. DC1 and WIN1 each use 2 vCPU / 6 GiB RAM / 64 GiB disk. APP1 uses 2 vCPU / 4 GiB RAM / 32 GiB disk. Guest totals are **6 vCPU / 16 GiB RAM / 160 GiB disk**. Measure Dell host and storage reserves, including temporary restore capacity, and assess the one bare-metal HP OPNsense firewall separately. Verify switch and bridge separation, including the absence of host addressing or routing on workload bridges. Physical HP OPNsense alone routes between zones with default deny. Windows host firewalls enforce same-zone limits and APP1 enforces its own host policy. Verify named management access, supported multifactor authentication (MFA), Dell and HP console recovery and approved rollback. Match allowed and denied service tests, including ordinary-user management denial before login, to effective rules, logs and states. FF-01 through FF-08 · Capacity budget	FWR-02, FSC-02, FWT-02

ID	Required evidence	Mapping
FAC-03	**Directory and application roles.** Verify isolated ad.lab.test, DC1 Active Directory (AD) and Domain Name System (DNS) health, effective Group Policy and standard WIN1 logon. Confirm ava, eli and uma have standard rights. Initially LabReaders contains ava and eli, LabMaintainers contains eli, and LabAdmins contains only the separate privileged administrator. Apache uses distinct application passwords and manually mapped roles. Require all six outcomes with valid app credentials. After removing eli's maintenance role in AD and Apache, verify denial from both the existing authenticated browser and a fresh context while report access remains. Record both change times, actual request and denial times, cache handling and matched Apache role and log evidence. C01-C06	FWR-03, FSC-03, FWT-03
FAC-04	**Endpoint security.** Record supported Windows and Linux builds, verified media and updates. Verify Microsoft Defender, effective Windows firewall profiles, Group Policy and auditing. Confirm one zone NIC per workload and only APP1's approved overlay exception. Windows host rules limit same-zone access. APP1 has default-deny input and forwarding policies and IPv4 and IPv6 forwarding disabled. Match ordinary-user denial and approved administrator success on the same harmless action to effective privileges. Verify persisted APP1 rules after the approved reboot and console rollback readiness. Corroborate APP1 host enforcement with the approved HTTPS permit and known-listening denial, matched to the host rule and its log or counter.	FWR-04, FSC-04, FWT-04
FAC-05	**HTTPS trust.** Verify one lab-only offline certificate authority (CA) with an encrypted private key and one APP1 server certificate. Check the chain and CA constraints, server-authentication purpose, exact app.ad.lab.test subject alternative name (SAN), hostname, validity dates and remaining lifetime. Observe browser rejection before public-root import and trusted HTTPS afterward on the exact name. Verify the root is trusted only on approved lab clients and both private keys are protected. Record that the lab omits a certificate-revocation service.	FWR-05, FSC-05, FWT-05
FAC-06	**Remote access and revocation.** Verify APP1 and one approved existing remote client are enrolled in a separate lab-only Tailscale network (tailnet) with lab identities, supported MFA and recovery. Grant only APP1 TCP 443. Inspect additive grants, device authorization and the client's path, including the absence of a direct route to APP1. Subnet routing, exit nodes, Tailscale SSH, Funnel, Serve and sharing stay off. Exclude DC1, WIN1, Proxmox and OPNsense. HP controls routed transport. Tailscale grants and independent APP1 host rules restrict the overlay, and Apache enforces page roles. Require working approved HTTPS, unauthorized-identity denial and a known-listening wrong-port denial. Use a lab-owned wrong-resource mock when required. Match each denial to the enforcing control using grant, device, host and application evidence as applicable. Confirm working HTTPS before removing the grant and exact device authorization. Verify denied network requests from existing and fresh sessions. Record state or cache handling and actual time to each denial. Keep the test NOT TESTED when independent safe egress is unapproved.	FWR-06, FSC-06, FWT-06
FAC-07	**Monitoring and investigation.** Verify E01 directory authentication success and E02 directory authentication failure in DC1 Security, E03 application access allowed and E04 application access denied in APP1 Apache, and E05 firewall access denied in physical HP OPNsense. Use bounded approved actions and valid app credentials for E04. Verify log access and rotation. Compare source and observer times in Coordinated Universal Time (UTC). Explain one denied-access event with a working positive control, the matching effective rule or role, and a second observation. Keep raw logs private. An approved two-source collection must still preserve attributable originating records for all five categories.	FWR-07, FSC-07, FWT-07

ID	Required evidence	Mapping
FAC-08	**Local capacity summary.** Verify exactly one manual WIN1 disk-capacity operation run locally as a standard user. Confirm the target identity and private output-path guard. Require two successful runs, separate invalid-target and invalid-path rejections, and an independent operating system comparison. Compare before and after state for the runs and rejections. Only the intended private summary may change, without elevation.	FWR-08, FSC-08, FWT-08
FAC-09	**Encrypted backup and isolated restore.** Verify one full encrypted off-compute APP1 backup on verified encrypted external storage. Record the archive's scope, age and separate recovery-key custody. Preserve original APP1 and the sole backup. Keep the original off during backup and the drill. Restore once to an approved unused temporary VM ID. Before boot, disconnect all restored NICs and disable autostart. Confirm copied Tailscale is inactive and disabled. Verify file hashes and content against the preserved original manifest before attachment. Use only the approved isolated WIN1-to-copy path through physical HP OPNsense with narrow temporary permissions. Keep upstream and nonparticipants disconnected. Over trusted HTTPS, verify ava can read reports and is denied maintenance. Measure from restore confirmation to verified integrity and usable HTTPS with a separate clock. Verify the copy is disconnected and stopped before rollback, then verify the original's final state and off-compute custody. Record the AD, CA, Dell host and physical-firewall recovery exclusions. Restore approval gate	FWR-09, FSC-09, FWT-09
FAC-10	**Evidence and handover.** Require actual evidence and second observations for all 91 mandatory subchecks across the ten tests. Resolve critical and high safety issues. Complete the five submission files and validate Markdown links, reproducible PDFs and the Office files. Review the public files, metadata, staged changes and new history. Publish only reviewed sanitized submissions and evidence. Keep private originals, raw records, credentials, keys and backups outside Git. Record the final pull request (PR), final-head continuous integration (CI) results, merge and local, tracking and live main synchronization. Record the engineering verifier and evidence cutoff, then obtain a separate explicit owner decision. Submission files · Owner UAT record	FWR-10, FSC-10, FWT-10

2. Phase gates and stage approvals

Stage L's automation and recovery portions need their own approval and may precede final stage K validation.

Table 2. Phase gates and stage approvals

Phase	Exit evidence
1. Prepared Infrastructure	Prepared assets, disk and data protection, compatible versions, measured capacity, three-zone path and Dell/HP console recovery verified. Resolve isolation and readiness blockers before dependent work.
2. Identity and Endpoint Security	Directory and DNS health, standard logon, effective Windows/Linux protections and separated privileges verified.
3. Zero Trust Access Controls	Six application cases and revocation, one CA and server certificate, and APP1-only remote permit, deny and revoke evidence.
4. Monitoring, Automation and Recovery	Five attributable events, one explained denial, one repeatable WIN1 capacity summary and one measured isolated APP1 restore.
5. Validation and Final Submission	All mandatory checks pass with traceable evidence. Five completed files, rubric evaluation, reviewed publication and separate owner decision are recorded.

2.1. Restore approval gate

Operational restore remains **BLOCKED** until the owner approves both the encrypted external-storage backend and recovery procedure and the exact isolated physical path, disconnection and rollback checklist. Keep the restore and its unperformed checks **NOT TESTED** until approved execution supplies the required evidence. Private recovery prerequisites

3. Engineering verification record

Record stage and approval date, scope and versions, requirement/control/test/FAC IDs, expected and actual results, verifier and date, evidence reference, second observation, defects, recovery state and verdict. Use all 91 mandatory child rows in **Deliverable 03 > Test Cases** and link their evidence in **Evidence Index**. Preserve failure evidence and record the approved correction, rollback and retest.

For network denials, require a working allowed control on the known-listening lab service. Match network and application denials to the effective rule, grant or role and its log, counter or device evidence. Use the matched administrator control for local privilege denial and the trusted and untrusted handshakes for certificate trust. A failed connection alone leaves enforcement unverified. Record the second technical observation separately from any human review.

- **PASS.** The actual result matches the expectation and all required evidence and second observations are verified.
- **FAIL.** An executed mandatory check has an observed mismatch.
- **NOT TESTED.** The check is blocked, unperformed or lacks required verification.

Overall FWT PASS requires every mandatory child to pass. Any failed child makes the overall test FAIL. Otherwise, an incomplete test remains NOT TESTED. NOT APPLICABLE cannot waive a mandatory check.

Critical failures involving isolation, privilege or authorization, Transport Layer Security (TLS) trust, remote exposure, recovery integrity, secret disclosure or false results block final acceptance at any score. Apply the 100-point rubric to verified results and retain every mandatory gate. Evaluation rubric

4. Submission files

Complete private working copies of these five released templates. Submit reviewed, sanitized files and link each claim to actual evidence. Blank templates, documentation checks, CI and historical task records establish documentation evidence only.

- 01-Lab-Environment-and-Architecture.xlsx
- 02-Identity-and-Zero-Trust-Implementation.docx
- 03-Security-Monitoring-and-Testing.xlsx
- 04-Troubleshooting-and-Lessons.xlsx
- 05-Final-Project-Submission.docx

5. Owner UAT record

Owner user acceptance testing (UAT) is a separate decision. Review analyst report access, engineer maintenance access, unassigned-user denial, remote access and revocation, and the recovery and evidence records. Record the reviewer, date, observed usability, limits, follow-ups and the explicit owner decision with its confirmation reference in **Deliverable 03 > Owner Acceptance**. Keep UAT **PENDING** until that decision is recorded.